

JÜRİ KİTAPÇIĞI

Sunum Taktikleri ve Soru-Cevap

Q-ADAPTIVE (AI Guardian)
Yapay Zekâ Güdümlü, Kuantum Dirençli Akıllı Cüzdan

Takım: CryptoTEK · TAKIM ID 909630
TEKNOFEST 2026 — Blokzincir Yarışması
Final: 30 Eylül – 4 Ekim 2026, Şanlıurfa

Bu kitapçık nasıl kullanılır

Her soru üç katmanlı cevaplanır. Sahnede yalnızca KISA CEVAP'ı söyleyin; jüri üstüne giderse DERİNLEŞİRSE katmanını açın. TUZAK satırı, o soruda düşülebilecek hatayı gösterir.

Katman	Ne zaman	Süre
KISA CEVAP	Her zaman. İlk cümle bu olmalı.	20–30 saniye
DERİNLEŞİRSE	Jüri "nasıl", "neden", "göster" derse.	1–2 dakika
TUZAK	Söylemeden önce okuyun. Sahnede değil, hazırlıkta.	—

Bu kitapçık eskisinin yerine geçer. Depodaki eski savunma kitapçığı düzeltilmiş sayıları öğretiyordu: %97,98 · 96-bit · 12/12 test · 16 özellik. Ondan çalışan bir ekip, sahnede ekrandaki güncel rakamlarla çelişir. Eski PDF'i kullanmayın.

Ezberlenmesi gereken yedi sayı

Bunlar en sık sorulacak sayılardır. Yanlış söylemek, ekranda doğrusu yazdığı için anında yakalanır.

Ne	Doğru değer	Yanlış söylenirse
ML-DSA imza boyutları	2.420 / 3.309 / 4.627 bayt	4.595 diye ezberlemeyin — o eski ve yanlış.
STARK güvenliği	80 bit (varsayımsal)	96-bit demeyin. Kodda 80 yazıyor ve bir test README'yi okuyor.
Alan	f128 (128-bit)	Goldilocks demeyin — o başka bir alan, biz kullanmıyoruz.
AI özellik sayısı	3 (İşlem sıklığı, IP sapması, Gas sapması)	16 demeyin. Jüri calibration_metadata.json'u açarsa üç sütun görür.
Otomatik test	244	12/12 demeyin. O sayı bir dönem ONNX katmanına aitti.
Calldata tasarrufu	50'lik partide %96,6–98,4	Tek bir yüzde vermeyin; kademeye göre değişir.
Dal kapsamı	%82,55 toplam	"%100 kapsam" demeyin.

1. Sunum taktikleri

1.1 Açılış — ilk 30 saniye

Jüri gün boyu sunum dinliyor. İlk cümlede ne yaptığınızı söyleyin; tarihçe, motivasyon ve teşekkür sonra gelir.

Açılış cümlesi: «Bugünkü cüzdanlar tek bir güvenlik seviyesine sabitlenmiştir. Biz, tehdit görüldüğünde kendini otomatik olarak kuantum dirençli bir imzaya yükselten bir cüzdan yaptık — ve bu yükselmenin gerçekten olduğunu matematiksel bir kanıtla gösteriyoruz.»

Ardından tek nefeste sınırı da söyleyin. Bu, güvenilirliği en hızlı kuran hamledir: «Baştan söyleyelim: ürettiğimiz kanıt imzanın kendisini ispatlamıyor, imzanın türetildiği kafes ilişkisini ispatlıyor. Farkı birazdan ekranda göstereceğim.»

1.2 Üç dakikalık akış

Dakika	Ne yapılır	Hangi ekran
0:00–0:30	Açılış cümlesi + sınırın peşin söylenmesi	Boş konsol
0:30–1:00	Standart senaryo koşturulur: risk düşük, kanıt yok	Nedensellik kartları
1:00–1:45	Drainer senaryosu: zırh 87'ye çıkar, kanıt üretilir	Kartlar + yürütme izi
1:45–2:15	Kafes büyümesi ve kurcalama rozetine işaret	Kafes ızgarası
2:15–2:40	Sınırları SÖZLÜ anlat — ekranda panel yok	Kafes / kartlar
2:40–3:00	Determinizm: aynı girdi aynı kanıt	Tekrar koşu

1.3 Demo koreografisi — altı adım

Arayüzde Sunum Modu yoktur — kaldırıldı, konsol tek bir çalışma ekranı. Aşağıdaki altı adımı siz yürütürsünüz: ilgili senaryo düğmesine basın, Enter ile koşturun, karşılık gelen itirazı anlatın. Tema için T.

Sınırlar ekranda değil. «İddia Etmediklerimiz» paneli de arayüzden kaldırıldı. Altıncı adımda işaret edeceğiniz bir panel yok; sınırları sözlü söylemeniz gerekiyor. Bu kitapçığın 4. bölümü tam olarak bunun için var.

Adım	Gösterilen	Cevapladığı itiraz
1	Standart senaryo — kanıt üretilmiyor	«Her işlemde ağır kripto mu çalışıyor?» Hayır.
2	Drainer — kafes 16'dan 56 hücreye çıkıyor	«Zırh değişimi gerçek mi, yoksa etiket mi?»
3	Kurcalama testi — doğrulama kırmızıya dönüyor	«İmza gerçekten çalışıyor mu?»
4	Rotasyon — p' değişince tüm hücreler değişiyor	«Hareketli hedef savunması somut mu?»

Adım	Gösterilen	Cevapladığı itiraz
5	Taban kuralı — zırh düşürülemiyor	«Saldırgan zırhı indirebilir mi?»
6	Determinizm — aynı girdi, aynı çıktı	«Bu sayılar uydurma olabilir mi?»
+	Sınırları sözlü say (ekranda panel yok)	«Neyi iddia etmiyorsunuz?»

1.4 En güçlü üç hamle

- Kurcalama rozeti. «İmzanız çalışıyor mu?» sorusuna bir teste atıfla değil, ekranda o anda yanan bir rozetle cevap verin. Her koşuda mesaj bozulur ve doğrulayıcının reddettiği görülür.
- Determinizm. Jüriden bir girdi isteyin, koşun, sonra aynı girdiyle tekrar koşun. p' , anahtar ve imza birebir aynı çıkar. «İsterseniz siz de kendi makinenizde üretebilirsiniz» deyin.
- Kendi aleyhinize olan ölçüm. Kart 4'teki «ECDSA'yı yeniyor mu → hayır» satırını siz gösterin. Ölçüm yaptığınızın en güçlü kanıtı, kendi aleyhinize çıkan sayıyı da ekranda tutmanızdır.

1.5 Demo çökerse — Plan B

Sunucu 18 saniyede açılıyor; sahneye çıkmadan önce açık olsun. Yine de kötü bir şey olursa:

Sorun	Ne yapılır
Sunucu yanıt vermiyor	Arayüz kırmızı bant gösterir ve tüm alanlar «—» olur. Bunu bir kusur değil, tasarım olarak sunun: «Ekranda gördüğünüz her sayı canlı bir koşudan gelir; sunucu yoksa hiçbir sayı göstermeyiz. Eski sürümümüz burada örnek veriye düşüyordu, denetimde bunu kapattık.»
Kanıt üretimi uzun sürüyor	Yürütme izi şeridini gösterin; aşamalar sırayla yanar. Bekleme sırasında AIR kısıtlarını anlatın.
Projeksiyon/internet yok	Arayüz sıfır CDN ile yazıldı; internetsiz tam çalışır. Bunu söyleyin, puan getirir.
Ekran çok karanlık/aydınlık	T tuşu temayı değiştirir. Koyu varsayılan, salon aydınlıkta açık temaya geçin.

1.6 Zor soru geldiğinde — dört adım

Adım	Ne yapılır	Örnek
1. Kabul et	Sorunun haklı olduğunu kabul edin. Savunmaya geçmeyin.	«Haklısınız, bu bizim en çok yanlış anlaşılan noktamız.»
2. Net cevap ver	Tek cümlede doğruyu söyleyin.	«Kanıt imza doğrulamasını ispatlamıyor.»
3. Ne yaptığınızı söyle	Yapmadığınızı söyledikten sonra yaptığınızı söyleyin.	«İmza ayrıca ve gerçekten atılıyor; boyutları ekranda.»
4. Kanıtı göster	Ekrana ya da bir teste işaret edin.	«Şu rozet her koşuda kurcalanmış mesajı reddediyor.»

1.7 «Bilmiyorum» nasıl söylenir

Bilmediğiniz bir şey sorulduğunda uydurmak, sahnede yapılabilecek en pahalı hatadır. Tek bir yakalanma, doğru söylediğiniz her şeyi de şüpheli hâle getirir.

Kalıp: «Bunu ölçmedik, dolayısıyla bir sayı veremem. Öltüğümüz şey şu: ... Eğer isterseniz ölçüm yöntemini anlatabilirim.»

Bu cümle sizi zayıf göstermez; neyi bilip neyi bilmediğini ayırt edebilen bir ekip gösterir. Jüri gün boyu bunun tersini dinliyor.

1.8 Sahnede kullanılmayacak cümleler

Bunlar doğru değildir. Ekranda ve belgelerde tersi yazılı olduğu için söylenirse anında çelişki doğar.

Söylemeyin	Bunun yerine
«STARK, ML-DSA doğrulamasını ispatlıyor»	«STARK, imzanın türetildiği kafes ilişkisini ispatlıyor; imza doğrulaması devre içinde değil.»
«Kanıt zincirde doğrulanıyor»	«Zincir kanıtın uzunluğunu kontrol ediyor ve guardian'ın ECDSA imzasını doğruluyor. STARK doğrulaması zincir dışında.»
«Mainnet'e / testnete konuşlandırdık»	«Konuşlandırma betiği hazır ve yerelde anvil'e karşı uçtan uca koştı; genel bir ağa göndermedik.»
«ECDSA'dan daha az calldata»	«ML-DSA imzası taşımaya kıyasla %98 tasarruf. ECDSA'ya kıyasla değil — 50 ECDSA imzası bizden küçük.»
«Bağımsız denetimden geçti»	«Slither ve solhint Cl'da koşuyor; insan denetimi yapılmadı.»
«%100 test kapsamı»	«Satır kapsamı %96,10, dal kapsamı %82,55. %100 demiyoruz.»
«Sertifikalı metrikler»	«Kendi ölçümlerimiz; hiçbir kurum sertifikalandırmadı.»
«12/12 test geçiyor»	«244 otomatik test geçiyor.»

2. Klişe sorular

Bunlar neredeyse kesin sorulur. Kısa, net ve ezberlenmiş cevaplanmalı; burada takılmak kötü bir izlenim bırakır.

2.1. Bu proje kısaca ne yapıyor?

KISA CEVAP

Bir kripto cüzdanının güvenlik seviyesini tehdide göre canlı olarak değiştiriyor. Yapay zekâ işlem davranışında anomali görürse, cüzdan kendini kuantum dirençli daha güçlü bir imzaya yükseltiyor ve bu geçişi matematiksel bir kanıtla belgeliyor.

DERİNLEŞİRSE

Üç kademe var: ML-DSA-44, -65 ve -87. İmza sırasıyla 2.420, 3.309 ve 4.627 bayt. Kademeyi seçen kural tek bir fonksiyonda ve hem Rust hem Python aynı kuralı uyguluyor; 13 sınır vektörüyle bir eşitlik testi ikisinin aynı kararı verdiğini doğruluyor.

TUZAK

«Kuantum güvenli cüzdan yaptık» deyip kesmeyin. Asıl yenilik kuantum imzayı kullanmak değil, ne zaman kullanacağına karar vermek.

2.2. Ne işe yarıyor? Gerçek bir problemi mi çözüyor?

KISA CEVAP

İki gerçek problemi birden. Birincisi drainer saldırıları: özel anahtar çalınınca klasik cüzdanda hiçbir ara katman yok, saldırgan her şeyi tek işlemle boşaltıyor. İkincisi kuantum tehdidi: bugünkü ECDSA imzaları Shor algoritmasıyla kırılabilir.

DERİNLEŞİRSE

Kuantum tehdidinin bugün başladığını vurgulayın: saldırgan bugün zincirdeki açık anahtarları kaydedip, kuantum bilgisayar geldiğinde geçmişe dönük çözebilir. Blokzincir verisi kalıcı ve herkese açık olduğu için buna «şimdi topla, sonra çöz» deniyor. Geçişin kuantum bilgisayar gelmeden önce yapılması gerekiyor.

2.3. Bunu daha önce yapan var mı? Sizin farkınız ne?

KISA CEVAP

Parçaların her biri ayrı ayrı var: ERC-4337 akıllı cüzdanlar var, post-kuantum imza kütüphaneleri var, ZK kanıt sistemleri var. Bizim yaptığımız, güvenlik seviyesini çalışma anında bir yapay zekâ kararına bağlamak ve bu kararı zincire taşımak.

DERİNLEŞİRSE

Somutlaştırın: Safe (eski adıyla Gnosis Safe) çoklu imza sunar ama imza şeması sabittir. Argent sosyal kurtarma sunar, yine sabit şema. zkSync ZK kullanır ama ölçeklenme için, adaptif güvenlik için değil. Bizde üç katman birbirine bağlı: AI kararı → kripto kademesi → zincir uygulaması.

TUZAK

«Dünyada bir ilk» demeyin. Kanıtlayamazsınız ve jüri bunu sorar. Bunun yerine birleşimin yeni olduğunu söyleyin.

2.4. Neden bu projeyi seçtiniz?

KISA CEVAP

Post-kuantum geçişi bir «ne zaman» sorusu, «olur mu» sorusu değil. NIST standartları 2024'te yayımlandı. Ama herkesin yarın ağır imzalara geçmesi pratik değil — maliyet çok yüksek. Bu aradaki geçiş problemini çözmek istedik.

2.5. Bu gerçekten çalışıyor mu, yoksa bir maket mi?

KISA CEVAP

Çalışıyor ve şu anda çalıştırabiliriz. Ekrandaki her sayı canlı bir koşudan geliyor; sunucuya ulaşamazsa arayüz hiçbir sayı göstermiyor, tüm alanlar «—» oluyor.

DERİNLEŞİRSE

Bunu bilerek böyle yaptık. Önceki sürümümüz API'ye ulaşamayınca sessizce örnek veriye düşüyordu — sunucu çökse bile ekran dolu görünüyordu. Denetimde bunu bulduk ve kapattık. Şimdi bir test, arayüzdeki 38 bağlı alanın her birinin API şemasında gerçekten var olduğunu her CI koşusunda doğruluyor.

2.6. Kaç kişisiniz, ne kadar sürdü?

KISA CEVAP

Takım CryptoTEK. Süreyi ve rol dağılımını ekip olarak siz cevaplayın — bu kitapçık teknik cevapları içerir.

TUZAK

Süreyi abartmayın; jüri kod tabanının boyutuyla karşılaştırır.

2.7. Hangi teknolojileri kullandınız ve neden?

KISA CEVAP

Dört katman, dört dil — her biri kendi işinde en iyisi olduğu için. Python yapay zekâ için (ONNX, scikit-learn). Rust kriptografi ve kanıt üretimi için (fips204, Winterfell) — bellek güvenliği ve başarımlar. Solidity zincir tarafı için, çünkü EVM'in tek dili. Arayüz sıfır bağımlılıkla saf HTML/JS.

DERİNLEŞİRSE

Arayüzün sıfır CDN olması bilinçli: sahnede internet olmayabilir. Eski sürüm Tailwind ve Chart.js'i internette çekiyordu; internetsiz arayüz çıplak kalırdı. Bir test bu kuralı zorluyor.

2.8. Ticarileşebilir mi? İş modeli var mı?

KISA CEVAP

Teknik olarak bir cüzdan altyapısı; ERC-4337 uyumlu olduğu için mevcut ekosisteme takılabilir. Ama bu bir prototip; üretim için bağımsız güvenlik denetimi ve guardian anahtarının HSM'e taşınması gerekir.

TUZAK

Gelir modeli uydurmayın. «Henüz ticarileştirmeyi çalışmadık, odağımız teknik doğruluktur» demek daha güvenli ve dürüst.

2.9. Kodu siz mi yazdınız? Yapay zekâ mı yazdı?

KISA CEVAP

Kodu biz yazdık ve her satırının neden orada olduğunu açıklayabiliriz. Kod tabanında 244 otomatik test var ve her testin hangi bulguyu koruduğu belgeli.

DERİNLEŞİRSE

Bunu kanıtlamanın en iyi yolu bir tasarım kararını anlatmaktır. Örnek: oracle bayatladığında ne raporlayacağımıza karar verirken iki yönü de elelediğimizi anlatın — fail-open saldırıyı ödüllendirir, fail-closed cüzdanı kilitler; biz «azami risk, panik kapalı» seçtik. Bu tür bir gerekçeyi ancak kodu düşünen biri anlatabilir.

TUZAK

Savunmaya geçmeyin. Bir karar anlatın — en güçlü cevap budur.

3. Teknik sorular

3.1. Yapay zekâ nasıl karar veriyor?

KISA CEVAP

Üç özellikli bir davranış vektörü alıyor — işlem sıklığı, IP sapması ve gas sapması — ve bir Isolation Forest modeliyle anomali skoru üretiyor. Skor, dinamik bir eşikle karşılaştırılıyor.

DERİNLEŞİRSE

Isolation Forest etiketsiz anomali tespiti için tasarlanmış. Mantığı ters çalışır: veriyi rastgele bölmelerle ayırır ve bir noktanın tek başına kalması için kaç bölme gerektiğine bakar. Sıra dışı noktalar birkaç bölmede yalnız kalır. Bizde 300 ağaç, contamination 0,03.

TUZAK

Özellik sayısını 3 söyleyin. Belgelerimiz bir dönem 16 diyordu; düzelttik. Jüri model dosyasını açarsa üç sütun görür.

3.2. Neden sabit bir eşik değil de dinamik eşik?

KISA CEVAP

Sabit eşik iki yönde de hatalı: ağ sakinken çok geç uyarır, ağ çalkantılıyken sürekli yanlış alarm verir. Bizim eşişimiz son 50 gözlemin varyansından hesaplanıyor.

DERİNLEŞİRSE

Formül: $\tau(t) = 60,0 + 0,15 \cdot \sigma^2(\text{gas}) + 0,08 \cdot \sigma^2(\text{frekans})$, sonuç $[55,0 - 90,0]$ aralığına sıkıştırılıyor. Varyans Bessel düzeltmesiyle (ddof=1) hesaplanıyor çünkü pencere tüm nüfusun değil bir örneklemin özeti. Pencerede 5'ten az gözlem varsa soğuk başlangıç değeri 75,0 kullanılıyor. Sıkıştırma şart: eşik ne tespit edilemez ne de her şeyi anomali sayan bir değere saplanabilir.

3.3. ML-DSA nedir, neden onu seçtiniz?

KISA CEVAP

NIST'in post-kuantum imza standardı, FIPS 204. Yarışmadaki adı CRYSTALS-Dilithium. Kafes tabanlı, yani güvenliği MLWE probleminin zorluğuna dayanıyor — Shor algoritması bunu çözmiyor.

DERİNLEŞİRSE

Üç kademesini de kullanıyoruz ve kademe çalışma anında seçiliyor. Gerçek bir kütüphane kullanıyoruz (Rust `fips204`); bir test her koşuda üretilen anahtar ve imza uzunluklarını FIPS 204 tablosuyla karşılaştırıyor, uyuşmazsa yapı kırılıyor.

TUZAK

«Dilithium yazdık» demeyin — standart kütüphaneyi kullanıyoruz, kendi kriptomuzu yazmadık. Bu bir güç, zayıflık değil: kendi kriptosunu yazmak kötü bir işarettir.

3.4. Neden üç kademe? İki ya da beşi olamaz mıydı?

KISA CEVAP

Üç kademe ML-DSA standardının kendi kademeleri — NIST kategori 2, 3 ve 5. Biz uydurmadık, standardı takip ettik.

DERİNLEŞİRSE

Kademeler arası geçiş eşiğin ne kadar aşıldığına bağlı: aşım ≥ 15 puan ise ML-DSA-87, ≥ 5 puan ise -65, aksi hâlde -44. Ayrıca seçilen kademe her zaman tabandan büyük ya da eşit olur — tek yönlü tırmanma.

3.5. Neden ZK-STARK? SNARK daha küçük kanıt üretmiyor mu?

KISA CEVAP

İki sebep. Birincisi STARK şeffaf: güvenilir kurulum töreni gerektirmiyor. SNARK'lar genelde gerektirir ve o kurulumdaki gizli veri sızarsa sahte kanıt üretilebilir. İkincisi STARK'ın güvenliği yalnızca hash fonksiyonlarına dayanıyor, eliptik eğrilere değil — yani kuantum bilgisayar STARK'ı kırmıyor.

DERİNLEŞİRSE

İkinci nokta bizim için belirleyici: post-kuantum bir sistemde, kanıt sisteminin kendisi kuantum kırılabilir olsaydı tüm mimari anlamsız olurdu. SNARK'ların çoğu eliptik eğri eşleşmelerine dayanır ve Shor altında kırılır.

TUZAK

SNARK'ı kötülemeyin; kanıt boyutunda SNARK daha iyidir. Takas şeffaflık ve post-kuantum güvenliği.

3.6. ERC-4337 neden gerekli?

KISA CEVAP

Normal bir Ethereum cüzdanı programlanamaz; kuralları zincir belirler ve yalnızca ECDSA kabul edilir. ERC-4337 cüzdanı bir akıllı sözleşmeye çeviriyor, böylece doğrulama mantığını biz yazabiliyoruz. Uyarlanabilir zırh ancak böyle mümkün.

DERİNLEŞİRSE

EntryPoint v0.7 kullanıyoruz ve CREATE2 sayesinde tüm ağlarda aynı adreste. Fork testlerimiz gerçek mainnet baytkoduna karşı koşuyor — mock değil, o adreste gerçekten kod olduğunu doğruluyoruz.

3.7. Paymaster nasıl kötüye kullanılmaz?

KISA CEVAP

Dört bağımsız kapı var: gönderen kontrolü, işlem başına azami maliyet, hesap başına dönem kotası ve toplam dönem bütçesi. Dördü de geçilmezse sponsorluk yok.

DERİNLEŞİRSE

Bu, denetimde bulduğumuz gerçek bir fon kaybı açığıydı: paymaster gönderene hiç bakmıyordu, yani herhangi bir saldırgan sözleşmesi gazını bize ödettirebiliyordu. Şimdi sömürü senaryosunun kendisi bir test olarak duruyor ve paymaster'ın satır kapsamı %100.

3.8. Zincirde gaz maliyeti ne kadar?

KISA CEVAP

validateUserOp için 26.449 – 147.510 gaz, medyan 74.155. Bu forge test --gas-report ile ölçüldü.

DERİNLEŞİRSE

Aralığın geniş olmasının sebebi, farklı kod yollarının farklı maliyeti olması: normal modda guardian imzası doğrulanmayabilir, panik modunda kanıt uzunluğu kontrolü ve ecrecover devreye girer.

TUZAK

Zincir üstü ML-DSA doğrulaması için gaz sayısı vermeyin. Öyle bir doğrulayıcı yazmadık; tahmini bir sayı söylemek yapmadığımız bir işi ölçmüş gibi göstermek olur.

3.9. ρ' rotasyonu tam olarak ne sağlıyor?

KISA CEVAP

Her rotasyonda yeni bir 32 baytlık tohum türetiliyor ve kafes matrisinin tamamı yeniden genişliyor. ρ' 'nün tek bir biti değişirse 56 hücrenin hepsi değişiyor — bir test bunu 56/56 olarak doğruluyor.

DERİNLEŞİRSE

Buna Hareketli Hedef Savunması deniyor: saldırganın keşif yaptığı yüzey sürekli değişirse, sabit bir hedefi inceleme avantajı kaybolur.

TUZAK

«Rotasyon kafes problemini zorlaştırıyor» demeyin. MLWE'nin zorluğu parametrelerden gelir, tohumdan değil. Rotasyonun sağladığı şey ileri güvenliktir — eski tohuma dair toplanan bilgi geçersiz olur. Bu ayırım arayüzdeki sınırlar panelinde de yazılı.

3.10. Kanıt üretimi ne kadar sürüyor?

KISA CEVAP

Kademeye ve makineye göre 0,4 – 21 ms arasında. Her koşuda yeniden ölçülüp yanıt yazılıyor, ekranda canlı görünüyor.

DERİNLEŞİRSE

Yürütme izi şeridinde 11 aşamanın her birinin süresi ayrı ölçülüyor: ONNX çıkarımı, zırh kararı, ρ' üretimi, kafes genişletme, ML-DSA keygen/imzalama/doğrulama, kurcalama testi, iz tablosu, STARK prover, yerel doğrulama.

TUZAK

Sabit bir sayı vermeyin. Belgelerimiz bir dönem «18.52 ms» diyordu; o tek bir makinedeki tek bir koşuydu ve sabitlenmişti.

4. Zor ve tuzak sorular

Bu bölümdeki sorular, ZK ya da kriptografi bilen bir jüri üyesinden gelir. Hepsinin ortak özelliği şudur: cevabı biliyorsanız güçlü, bilmiyorsanız yıkıcıdır. Hazırlığın ağırlığı buraya verilmeli.

4.1. STARK tam olarak neyi kanıtlıyor? İmza doğrulamasını mı?

KISA CEVAP

Hayır, imza doğrulamasını devre içinde ispatlamıyoruz ve bunu açıkça söylüyoruz. AIR üç kısıt uyguluyor: s_1 ve s_2 'nin ilerleyişi ve $t = A \cdot s_1 + s_2$ MLWE ilişkisi. Bu, imzanın türetildiği kafes ilişkisi — imza doğrulama devresi değil.

DERİNLEŞİRSE

İmzalama ayrıca ve gerçekten yapılıyor: aynı p' tohumundan türetilen ξ ile $\text{keygen_from_seed}(\xi)$ çağrılıyor, gerçek bir FIPS 204 imzası üretiliyor ve doğrulanıyor. STARK ile imza arasındaki bağ ortak tohum. Tam ML-DSA doğrulamasını bir STARK devresine kodlamak aylar süren, araştırma düzeyinde bir iş — bunu yapmadığımızı söylemek, yapmış gibi görünmekten iyidir.

TUZAK

Bu soruda en ufak bir belirsizlik bırakmayın. Kaçamak bir cevap verirsiniz jüri geri kalan her şeyi sorgular. Peşin söyleyin, hatta sunumun açılışında söyleyin.

4.2. Burada «sıfır bilgi» olan ne? p' zaten ekranda.

KISA CEVAP

Haklısınız. Buradaki sıfır bilgi nominaldir. p' arayüzde yayınlanıyor, dolayısıyla s_1 , s_2 ve A matrisi herkes tarafından yeniden hesaplanabilir. Kanıt özlüdür — doğrulaması tablonun tamamını görmekten ucuz — ama hiçbir sır gizlemez.

DERİNLEŞİRSE

Bu bilinçli bir takas: gizlilik yerine tekrarlanabilirliği seçtik. Jürinin aynı girdiyle aynı kanıtı kendi makinesinde üretebilmesi, bizim için gizlilikten daha değerliydi. p' 'yü gizleseydik determinizmi ve bağımsız doğrulanabilirliği kaybederdik.

TUZAK

Bu maddeyi arayüzdeki sınırlar paneli zaten yazıyor. Panelde yazanla çelişen bir şey söylerseniz, arkanızdaki ekranla çelişirsiniz.

4.3. Kanıt zincirde doğruluyor musunuz?

KISA CEVAP

Hayır. Sözleşme kanıtın uzunluğunu kontrol ediyor (en az 3.000 bayt) ve guardian'ın ECDSA attestation imzasını ecrecover ile doğruluyor. STARK doğrulaması zincir dışında.

DERİNLEŞİRSE

Bu bir eksiklik değil, mimarinin amacı: Solidity'de bir STARK doğrulayıcı çalıştırmak devasa gaz maliyeti demek — zaten kaçındığımız şey bu. Zincire giden şey 65 baytlık bir ECDSA imzası.

TUZAK

«Zincir kanıtı doğruluyor» demeyin. Jüri sözleşmeyi açarsa $\text{MIN_STARK_PROOF_BYTES} = 3000$ satırını görür ve bunun bir uzunluk kontrolü olduğunu anlar.

4.4. Testnete konuşlandırdınız mı? Canlı adres var mı?

KISA CEVAP

Hayır, hiçbir ağa konuşlandırmadık. Konuşlandırma betiği hazır, testlerle korunuyor ve yerelde anvil'e karşı uçtan uca koştur — ama genel bir ağa göndermedik.

DERİNLEŞİRSE

Betik adres basmakla yetinmiyor: konuşlandırmadan önce EntryPoint adresinde gerçekten baytkod olduğunu doğruluyor, sonra bağlantıları zincirden geri okuyor. Bu kontrol olmasa yanlış ağa konuşlandırma «başarılı» görünürdü — üç sözleşme iner, hiçbiri çalışmaz. Ayrıca fork testlerimiz gerçek mainnet EntryPoint baytkoduna karşı 4/4 geçti.

TUZAK

«Fork testi geçti» ile «testnette canlı» aynı şey değil. İkincisini söylemeyin.

4.5. Yapay zekâ yanılırsa ne olur?

KISA CEVAP

İki yönde de düşünüldü. Yanlış pozitifte (gereksiz alarm) kullanıcı daha ağır bir imza kullanır — yavaşlar ama güvendedir. Yanlış negatifte (kaçırılan saldırı) taban kademe devrede kalır; taban hiçbir zaman sıfır değildir.

DERİNLEŞİRSE

Kritik nokta: yanlış negatif korumayı sınırlamaz. Sistem her zaman en az taban kademede çalışır ve zincir üstünde tek yönlü tırmanma var — bir kez yükselmiş zırh düşürülemez. Ayrıca dinamik eşik yanlış pozitif oranını düşürmek için var: ağ çalkantılıyken eşik otomatik yükseliyor.

TUZAK

«AI hiç yanılmaz» demeyin. Yanılma senaryosunu siz anlatın.

4.6. Guardian anahtarı ele geçirilirse ne olur?

KISA CEVAP

Saldırgan sahte attestation üretebilir. Bu bilinen bir sınır: anahtar şu an süreç belleğinde tutuluyor ve sabit-zamanlı değil. Üretim için HSM ya da KMS'e taşınması gerekir.

DERİNLEŞİRSE

Hasarı sınırlayan iki şey var. Birincisi, zincir üstünde risk skoru oracle ile guardian'ın büyüğü alınıyor — guardian tek başına riski düşüremiyor. İkincisi tek yönlü tırmanma: ele geçirilen bir guardian zırhı indiremez. Ayrıca guardian anahtarı döndürülebilir ve rotasyon olayı indeksli, yani zincirden filtrelenebilir.

TUZAK

Bu soruyu savuşturmaya çalışmayın. «Bu bir prototip sınırı, üretim için HSM şart» demek doğru cevaptır.

4.7. Oracle susarsa? Yani zincir dışı sistem çökerse?

KISA CEVAP

Oracle bayat sayılır ve azami risk raporlar — ama panik modunu açmaz. Yani zırh en güçlü kademeye çıkar, cüzdan kullanılabilir kalır.

DERİNLEŞİRSE

Bu, sözleşmenin tek gerçek tasarım kararı ve iki yönü de eledik. Fail-open (bayatken risk=0) olsaydı, updater'ı susturabilen saldırgan zırhı en zayıf kademeye düşürürdü — saldırıyı ödüllendirirdi. Fail-closed (bayatken panik=true) olsaydı her işlem kanıt isterdi; zincir dışı yığın çöktüğü için bayatlamıştır, o kanıt kimse üretmez ve cüzdan kilitlenirdi. Üçüncü yolu seçtik. Ayrıca yeni konuşlandırılan oracle bilerek bayat başlar: henüz hiçbir şey ölçmemiştir, risk 0 raporlamak en tehlikeli yönde yalan olurdu.

4.8. Eğitim veriniz gerçek zincir verisi mi?

KISA CEVAP

Hayır, kontrollü sentetik veri. Canlı zincirden toplanmadı ve bunu gizlemiyoruz — README'de, belgelerde ve arayüzdeki sınırlar panelinde yazılı.

DERİNLEŞİRSE

Gerçek veriyle eğitim ayrı bir iş: etiketli saldırı verisi toplamak günler sürer ve yarışma kapsamını aşar. Ama mimari buna bağlı değil — model ONNX formatında, değiştirilmesi tek dosya değişikliği.

TUZAK

Sentetik olduğunu siz söyleyin. Jüri sorup öğrenirse çok daha kötü.

4.9. %98 tasarruf neye göre? Bu sayı nereden geliyor?

KISA CEVAP

50 işlemlik bir partide, işlem başına ML-DSA imzası taşımaya kıyasla. $50 \times 4.627 = 231.350$ bayt yerine tek bir kanıt, yaklaşık 4.000 bayt.

DERİNLEŞİRSE

Formül ve tüm girdileri her koşuda proof_payload.json içindeki calldata alanına yazılıyor — yani sayıyı bizim sunumumuza güvenmeden doğrulayabilirsiniz. Kademeye göre oran %96,6 ile %98,4 arasında değişiyor.

TUZAK

«ECDSA'dan %98 tasarruf» demeyin. Taban ML-DSA imzasıdır.

4.10. ECDSA'dan daha mı verimlisiniz?

KISA CEVAP

Hayır, calldata boyutunda ECDSA bizi yeniyor. 50 ECDSA imzası 3.250 bayt — tek bir STARK kanıtımızdan küçük. Arayüzde beats_ecdsa → hayır diye yazıyor ve bunu gizlemiyoruz.

DERİNLEŞİRSE

Takas edilen şey boyut değil, post-kuantum güvenliği. ECDSA'nın Shor algoritması altında sağlayamadığı tek şey bu. Bizim iddiamız «daha ucuz» değil, «kuantum sonrasında da geçerli».

TUZAK

Bu soruyu bir zayıflık gibi karşılamayın. Kendi aleyhinize olan ölçümü ekranda tutmanız, ölçüm yaptığınızın en güçlü kanıtı.

4.11. Kuantum bilgisayar daha yok. Bu erken değil mi?

KISA CEVAP

Tehdit gelecekte, ama hazırlık bugün yapılmalı. Saldırgan bugün zincirdeki açık anahtarları kaydedip, kuantum bilgisayar geldiğinde geçmişe dönük çözebilir.

DERİNLEŞİRSE

Buna «şimdi topla, sonra çöz» deniyor ve blokzincir için özellikle geçerli, çünkü zincir verisi kalıcı ve herkese açık. Bir bankada eski trafiği kaydetmek zordur; blokzincirde ücretsizdir. NIST standartları 2024'te yayımlandı; geçiş penceresi şimdi açık.

4.12. Madem ML-DSA-87 var, neden hep onu kullanmıyorsunuz?

KISA CEVAP

Maliyet. ML-DSA-87 imzası 4.627 bayt — ECDSA'nın ~71 katı. Blokzincirde her bayt para. İşlem başına bunu taşımak cüzdanı pratikte kullanılamaz hâle getirir.

DERİNLEŞİRSE

Projenin bütün fikri bu zaten: her zaman değil, gerektiğinde. Kullanıcıların çoğu, çoğu zaman saldırı altında değil. Tehdit görüldüğünde ağır kademeye çıkıyoruz ve bir kez çıkınca düşmüyoruz — tek yönlü tırmanma.

4.13. 80 bit güvenlik yeterli mi? Standart 128 değil mi?

KISA CEVAP

Haklısınız, 80 bit üretim için düşüktür. Bu bir prototip ayarı ve bilerek temkinli tutuldu; artırmak tek bir sabiti değiştirmek demek.

DERİNLEŞİRSE

Sayı tek bir yerden geliyor: `air.rs::STARK_SECURITY_BITS`. FRI sorgu sayısı (28) birlikte ayarlanması gerekiyor — ikisi bağımsız değil. Kanıt boyutu ve üretim süresi artar. Ayrıca README'yi okuyan bir test, belgedeki sayı ile koddaki sabitin ayrışmasını engelliyor.

TUZAK

«96 bit» demeyin. Belgelerimiz bir dönem öyle diyordu, kod 80 diyordu; bu tutarsızlığı denetimde bulduk ve düzelttik.

4.14. Testlerinizi çalıştırabilir miyim?

KISA CEVAP

Evet, buyurun. Komutlar belgede yazılı ve hepsi tek satır.

DERİNLEŞİRSE

Rust için cargo test (61 test), Solidity için forge test (146 test, 4'ü fork). Python tarafında üç takım: katman eşitliği (9), attestation kriptosu (18), API-arayüz sözleşmesi (9). Toplam 244. Katman eşitliği testi özellikle ilginç: gerçek Rust ikilisini çalıştırıp Python'un kararıyla karşılaştırıyor.

TUZAK

Bu soruya «isterseniz gösterelim» deyip geçiştirmeyin; gerçekten çalıştırın. Çalıştıramayacağınız bir iddiayı hiç yapmayın.

4.15. Kendi kodunuzda hata buldunuz mu?

KISA CEVAP

Evet, 21 bulgu ve sonradan çıkan yedi hata daha. Üçü canlı ağda sistemi tamamen çalışmaz hâle getirecek cinstendi.

DERİNLEŞİRSE

En çarpıcısı: ön-fonlama gas: 2300 ile yapılıyordu. Gerçek EntryPoint'in `receive()`'ı depolamaya yazar (~20.000+ gaz); 2.300 gaz yetmez, yani çağrı her zaman başarısız olur ve `require` yüzünden her işlem `revert` ederdi. Cüzdan canlı ağda hiçbir işlemi tamamlayamazdı. Bir diğeri: arayüzde gösterilen iz, STARK'ın kanıtladığı iz değildi. Hepsi için geri gelmeyi engelleyen testler yazdık.

TUZAK

Bu soruya bol bol cevap verin. Hata bulduğunu anlatabilen ekip, hiç hata bulmamış olduğunu iddia edenden çok daha güvenilir görünür.

5. Rakip karşılaştırma ve konumlandırma

«Farkınız ne?» sorusunun teknik hâli. Rakipleri küçümsemeyin; her biri farklı bir problemi çözüyor.

Çözüm	Ne yapıyor	Bizden farkı
Safe (Gnosis Safe)	Çoklu imza cüzdanı. Birden fazla onay gerektirir.	İmza şeması sabit ve ECDSA. Kuantum dirençli değil, uyarlanabilir değil.
Argent	Sosyal kurtarma: anahtar kaybolursa güvenilir kişiler kurtarır.	Kurtarma sonrası çözüm. Biz saldırıyı anında yavaşlatmaya çalışıyoruz. İmza şeması yine sabit.
zkSync / StarkNet	ZK kanıtları ölçeklenme için kullanıyor.	Aynı teknoloji, farklı amaç. Bizde ZK güvenlik kademesini belgelemek için.
Donanım cüzdanlar	Özel anahtarı fiziksel olarak izole eder.	Anahtar çalınmasına karşı güçlü, ama kuantuma karşı çaresiz — yine ECDSA imzalıyor.
PQ kütüphaneleri (liboqs vb.)	Post-kuantum imza şemalarını sağlar.	Biz de böyle bir kütüphane kullanıyoruz (fips204). Katkımız kütüphane değil, ne zaman hangi kademenin kullanılacağına karar veren katman.

Konumlandırma cümlesi: «Kimsenin yapmadığı bir kripto yazmadık — NIST'in standardını kullanıyoruz. Bizim kattığımız şey, güvenlik seviyesini çalışma anında bir tehdit değerlendirmesine bağlamak ve bu bağı zincire taşımak.»

5.1 Rakip sorusu tuzağı

Jüri bazen «X şirketi bunu zaten yapıyor» der. Panik yapmayın; üç adımda cevaplayın:

- Sorun: «Tam olarak hangi kısmını yapıyorlar?» — çoğu zaman parçalardan birini yapıyordur, birleşimi değil.
- Kabul edin: ortak yanı varsa söyleyin. «Evet, o katmanda benzer.»
- Farkı söyleyin: «Bizim eklediğimiz, kademenin çalışma anında seçilmesi ve bunun kanıtlanması.»

6. Süreç ve ekip soruları

6.1. En çok nerede zorlandınız?

KISA CEVAP

Katmanların birbirini tutmasında. Dört ayrı dil var ve başlangıçta aynı kararı farklı veriyorlardı — Rust sabit bir eşik kullanıyordu, Python dinamik eşik. İkisi farklı kademe seçebiliyordu.

DERİNLEŞİRSE

Çözüm tek bir kuralı iki dilde uygulamak ve bunu bir eşitlik testiyle sabitlemek oldu: test gerçek Rust ikilisini çalıştırıp Python'un kararıyla 13 sınır vektöründe karşılaştırıyor.

6.2. Neyi farklı yaptınız?

KISA CEVAP

Testleri daha erken yazardık. Solidity tarafında bir dönem hiç test yoktu ve orada gerçek bir fon kaybı açığı duruyordu — paymaster gönderene bakmıyordu.

DERİNLEŞİRSE

Bir de belgeleri koddan üretirdik. Belgelerimiz kaynak kodu alınılıyordu ama alıntılar donmuştu; bir fonksiyon değişince belge sessizce yanlış oluyordu. Şimdi 23 kod bloğu kaynaktan üretiliyor ve bir CI kapısı sapmayı yakalıyor.

6.3. Projede en çok neyle gurur duyuyorsunuz?

KISA CEVAP

Ekranda kendi aleyhimize olan ölçümün durması. «ECDSA'yı yeniyor mu → hayır» satırını silebilirdik; bırakmayı seçtik. Aynı şekilde sınırlarımız README'de bir tablo hâlinde duruyor ve bir test, maddelerden biri silinirse yapıyı kırıyor.

DERİNLEŞİRSE

Teknik olarak ise kurcalama testinin canlı hatta koşması. «İmzamız çalışıyor» iddiası bir teste atıf değil, her koşuda ekranda yanan bir rozet.

6.4. Bu projeyi sürdüreceksiniz mi?

KISA CEVAP

Yarışma sonrası yol haritası net: testnete konuşlandırma, guardian anahtarının HSM'e taşınması, bağımsız güvenlik denetimi ve dal kapsamının yükseltilmesi.

TUZAK

Süre ve kaynak taahhüdü vermeyin.

6.5. Kodunuz açık mı?

KISA CEVAP

Evet, Apache 2.0 lisansı ile GitHub'da. CI hattı da açık — altı iş, her koşu görülebilir.

7. Hızlı referans kartı

Bu sayfa sahnede önünüzde dursun. Tek bakışta gereken her sayı burada.

Sayılar

Ne	Değer
ML-DSA imza	2.420 / 3.309 / 4.627 bayt
ML-DSA açık anahtar	1.312 / 1.952 / 2.592 bayt
Kafes ($k \times l$)	$4 \times 4 = 16$ / $6 \times 5 = 30$ / $8 \times 7 = 56$ hücre
STARK güvenliği	80 bit varsayımsal · f128 alan · 28 FRI sorgusu
Kanıt boyutu	3.617 – 4.321 bayt (ölçülür)
Prover süresi	0,4 – 21 ms (ölçülür)
ONNX çıkarımı	8,8 – 10,1 ms (5 koşu ortalaması)
Boru hattı	11 aşama, her süre ölçülmüş
AI modeli	Isolation Forest · 300 ağaç · contamination 0,03 · 3 özellik
Dinamik eşik	$\tau = 60 + 0,15\sigma^2(\text{gas}) + 0,08\sigma^2(\text{frekans})$, [55-90]
Kademe eşikleri	$\text{aşım} \geq 15 \rightarrow 87 \cdot \geq 5 \rightarrow 65 \cdot \text{aksi} \rightarrow 44$
validateUserOp gazı	26.449 – 147.510 (medyan 74.155)
Calldata tasarrufu	50'lik partide %96,6 – 98,4 (ML-DSA tabanına göre)
50 ECDSA imzası	3.250 bayt — bizden küçük
Testler	Rust 61 · Solidity 146 · Python 37 = 244
Kapsam	satır %96,10 · dal %82,55 · fonksiyon %95,31
CI	6 iş
EntryPoint	v0.7 · 0x0000000071727De22E5E9d8BAf0edAc6f37da032

Üç cümlelik savunma

- «Kanıtımız imza doğrulamasını devre içinde ispatlamıyor; imzanın türetildiği kafes ilişkisini ispatlıyor. İmza ayrıca ve gerçekten atılıyor.»
- «Buradaki sıfır bilgi nominal — ρ ' yayınlanıyor, sır gizlemiyoruz. Gizlilik yerine tekrarlanabilirliği seçtik.»
- «Hiçbir ağa konuşlandırmadık. Betik hazır ve yerelde uçtan uca koştu; 'canlı' demiyoruz.»

Asla söylenmeyecek yedi cümle

- «STARK, ML-DSA doğrulamasını ispatlıyor»
- «Kanıt zincirde doğrulanıyor»

- «Testnete/mainnete konuşlandırdık»
- «ECDSA'dan daha az calldata»
- «Bağımsız denetimden geçti»
- «%100 test kapsamı» / «12/12 test»
- «Sertifikalı metrikler» / «96-bit güvenlik» / «16 özellik»